

Vulnerability Assessment Report

Target: Hackazon Web Application

Network Security Layers

Date: April 26, 2026

Eli Ecton

1. Executive Summary

This report covers a vulnerability assessment performed on the Hackazon web application, a deliberately vulnerable e-commerce platform developed by Rapid7 for security training. The assessment was done in an isolated virtual lab environment using Nmap, Tenable Nessus Essentials, and Nikto.

The assessment found a total of 22 vulnerabilities across the host and application layers, including one Critical, one Medium (CVSS 6.1), and one Low finding from Nessus, along with several web application issues found by Nikto. The most notable findings include an end-of-life operating system, exposed server configuration files, an enabled DEBUG HTTP method, and several missing HTTP security headers. These vulnerabilities pose a real risk to the security of the application and the data it stores.

Critical	High	Medium	Low
1	2	3	2

Table 1: Vulnerability count by severity

2. Scope and Methodology

The scope of this assessment is limited to the Hackazon web application running on a single host inside an isolated virtual network. No outside networks were involved.

Parameter	Details
Target Host	10.0.2.3
Target Application	Hackazon (Rapid7)
Target Port	TCP 80 (HTTP)
Assessment Date	April 26, 2026
Tester Machine	Kali Linux (VirtualBox VM)
Network	VirtualBox NAT Network (isolated)
Tools Used	Nmap 7.98, Tenable Nessus Essentials 10.12.0, Nikto 2.6.0

Table 2: Assessment scope and parameters

The assessment followed a three part process:

Part 1: Reconnaissance: Nmap was used to scan the target host for open ports, running services, service versions, and OS information. This gave a clear picture of what was exposed on the network.

Part 2: Vulnerability Scanning: Tenable Nessus Essentials was used to run a Basic Network Scan against the target, looking for host and service level vulnerabilities. Nikto was used to scan the web application specifically, finding issues like missing security headers, exposed files, and insecure settings.

Part 3: Analysis and Reporting: Findings from all three tools were reviewed and rated by severity. The most significant vulnerabilities were chosen for detailed analysis in this report.

3. Network Diagram

The assessment was run inside an isolated VirtualBox NAT Network. The diagram below shows the lab setup used during testing.

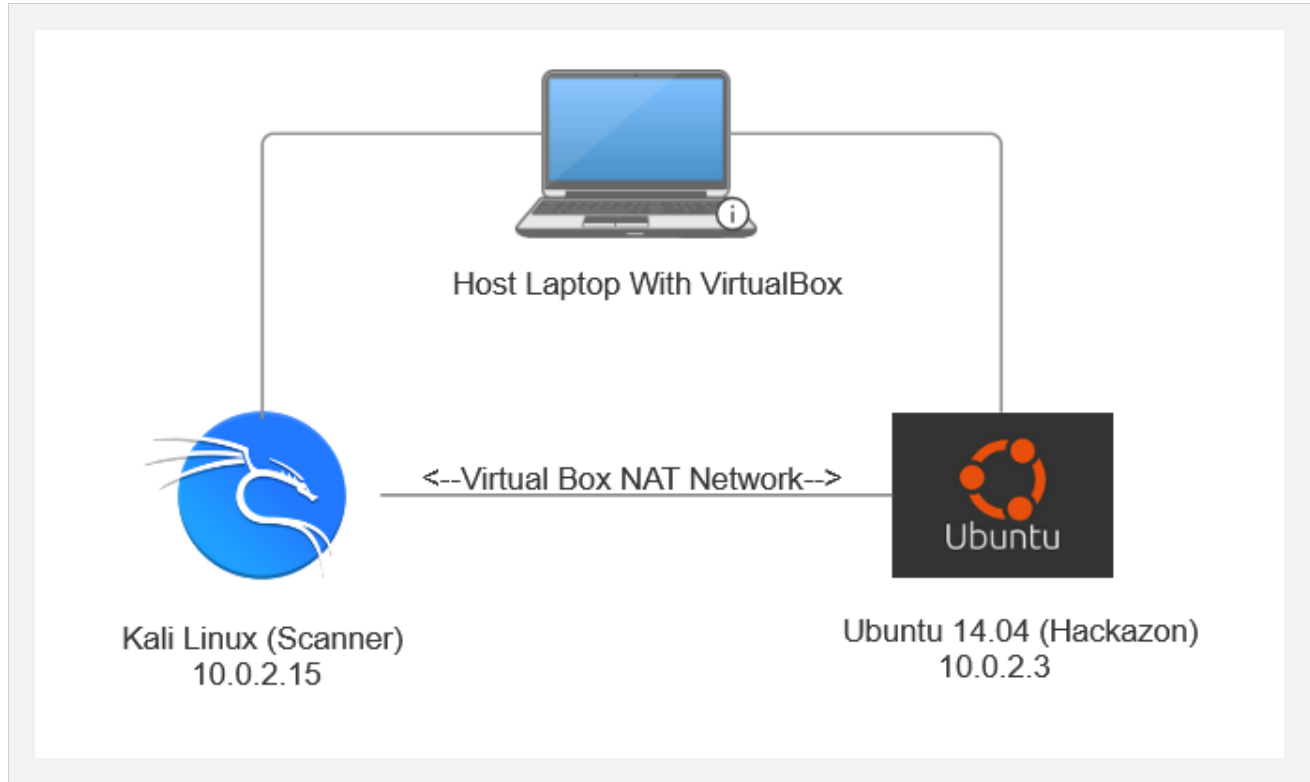


Figure 1: Lab network topology

The Kali Linux VM was used as the scanning machine, and the Ubuntu 14.04 VM running Apache, PHP, MySQL, and Hackazon was the target. Both machines were on a VirtualBox NAT Network with no connection to outside systems during the scan.

4. Scan Results

4.1 Nmap: Host Discovery and Port Scan

An Nmap scan was run against 10.0.2.3 using service version detection (-sV), default scripts (-sC), and OS detection (-O). The scan finished in under 30 seconds and found one open port.

```
26/04/26 5:02:21 (kali@kali)-[~]
└─$ nmap -sV -sC -O 10.0.2.3 -oN hackazon_scan.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 17:02 -0400
Nmap scan report for 10.0.2.3
Host is up (0.00088s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.7 ((Ubuntu))
|_http-title: Hackazon
|_http-cookie-flags:
|   /:
|   PHPSESSID:
|_   httponly flag not set
|_http-server-header: Apache/2.4.7 (Ubuntu)
MAC Address: 08:00:27:92:56:0B (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.64 seconds

26/04/26 5:03:08 (kali@kali)-[~]
└─$
```

Figure 2: Nmap scan results for 10.0.2.3

Port	State	Service	Version
80/tcp	Open	HTTP	Apache httpd 2.4.7 (Ubuntu)

Table 3: Nmap open port results

Nmap also flagged that the PHPSESSID session cookie was set without the HttpOnly flag, and identified the OS as Linux kernel 3.2–4.14, which matches Ubuntu 14.04.

4.2 Nessus: Network Vulnerability Scan

Tenable Nessus Essentials was used to run a Basic Network Scan against 10.0.2.3. The scan took about six minutes and found 22 vulnerabilities across all severity levels.

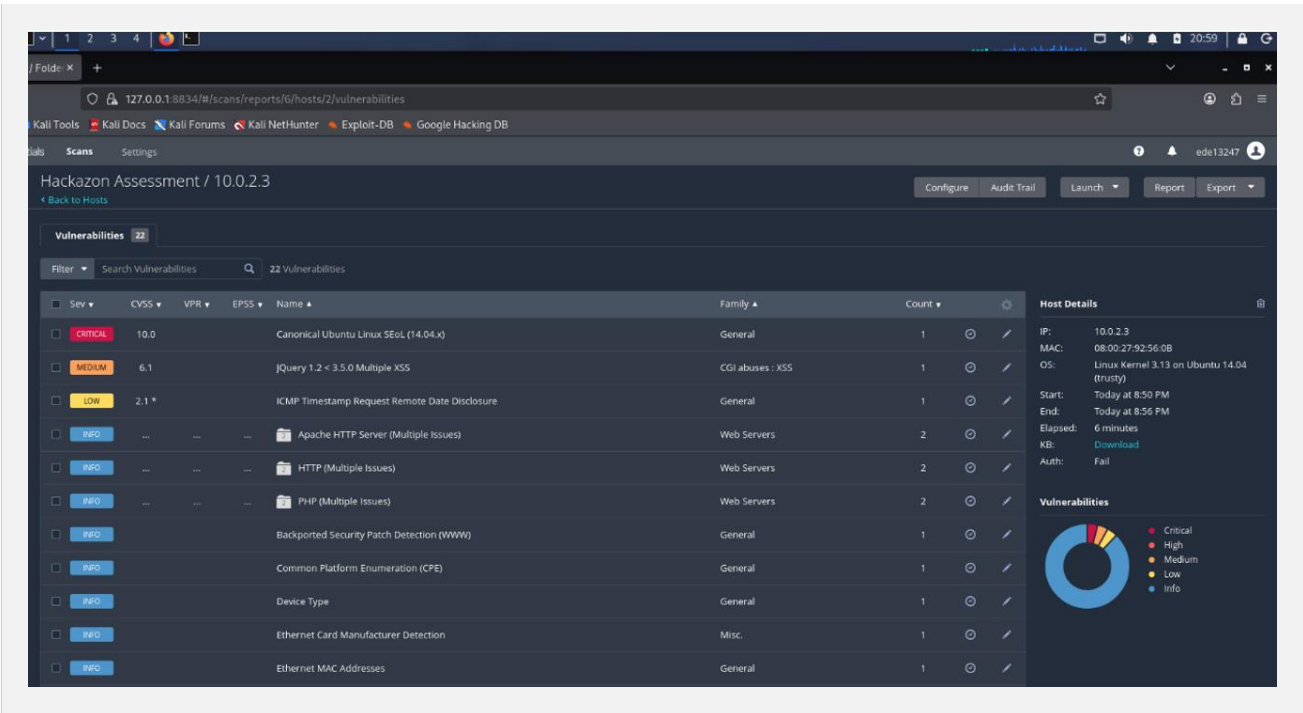


Figure 3: Nessus scan results summary for 10.0.2.3

Severity	Count	Notable Findings
Critical	1	Canonical Ubuntu Linux SEoL (14.04.x)
Medium	1	jQuery 1.2 < 3.5.0 Multiple XSS
Low	1	ICMP Timestamp Request Remote Date Disclosure
Info	19	Apache, HTTP, PHP version details and configuration data

Table 4: Nessus findings by severity

4.3 Nikto: Web Application Scan

Nikto v2.6.0 was used to scan the web application at http://10.0.2.3 on port 80. The scan found several issues including missing security headers, an insecure cookie setting, exposed configuration files, and an enabled DEBUG HTTP method.

```

26/04/26 9:13:22 (kali@kali)-[~]
└─$ cat nikto_results.txt
- Nikto v2.6.0/
+ Target Host: 10.0.2.3
+ Target Port: 80
+ GET /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies:
+ GET /: Retrieved x-powered-by header: PHP/5.5.9-1ubuntu4.29.
+ HEAD PHP/5.5.9-1ubuntu4.29 appears to be outdated (current is at least 8.5.1).
+ HEAD Apache/2.4.7 appears to be outdated (current is at least 2.4.66).
+ GET /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy:
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy:
+ JZ0LAHSG /: Web Server returns a valid response with junk HTTP methods which may cause false positives
+
+ DEBUG /: DEBUG HTTP verb may show server debugging information. See: https://docs.microsoft.com/en-us/visualstudio/debugger/how-to-enable-debugging-for-aspnet-applications?view=vs-2017:
+ GET /home/: This might be interesting.
+ GET /log.txt: This might be interesting.
+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/:
+ GET /helpdesk/: This might be interesting.
+ GET /wps/portal/Home/Welcome!ut/: IBM Websphere default portal found. May allow users to create accounts.
+ GET /redis_config.json: Redis config file found. It may contain sensitive information.
+ GET /credis/tests/redis_config.json: Redis config file found. It may contain sensitive information.
+ GET /config/redis.json: Redis config file found. It may contain sensitive information.
+ GET /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/:
+ GET /crossdomain.xml: A Flash cross-domain policy file was found. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-site.html:

```

Figure 4: Nikto web application scan results

5. Vulnerability Findings

This section covers the six most significant vulnerabilities found during the assessment. Each finding includes a severity rating, CVSS score where available, a description, the potential impact, and a suggested fix.

1. Ubuntu 14.04 LTS: End of Life Operating System

Field	Details
Severity	Critical
CVSS Score	10.0 (CVSS v3)
Discovered By	Tenable Nessus Essentials
Location	Host OS — 10.0.2.3

Description:

The target host is running Ubuntu 14.04 LTS (Trusty Tahr), which reached end of life on April 25, 2019. Since it is no longer supported, it does not receive security patches or updates anymore. Any vulnerabilities found in the OS kernel, system libraries, or installed packages after that date will never be fixed.

Potential Impact:

Running an end-of-life OS is one of the incredibly risky. Attackers can take advantage of known, publicly documented vulnerabilities with no chance of them being patched. This makes privilege escalation, remote code execution, and full system compromise much more likely.

Recommended Remediation:

The OS should be upgraded to a supported Ubuntu LTS release (22.04 or 24.04). After upgrading, all system packages and application dependencies should be reviewed and updated. In any real world environment, running a supported OS is a basic security requirement.

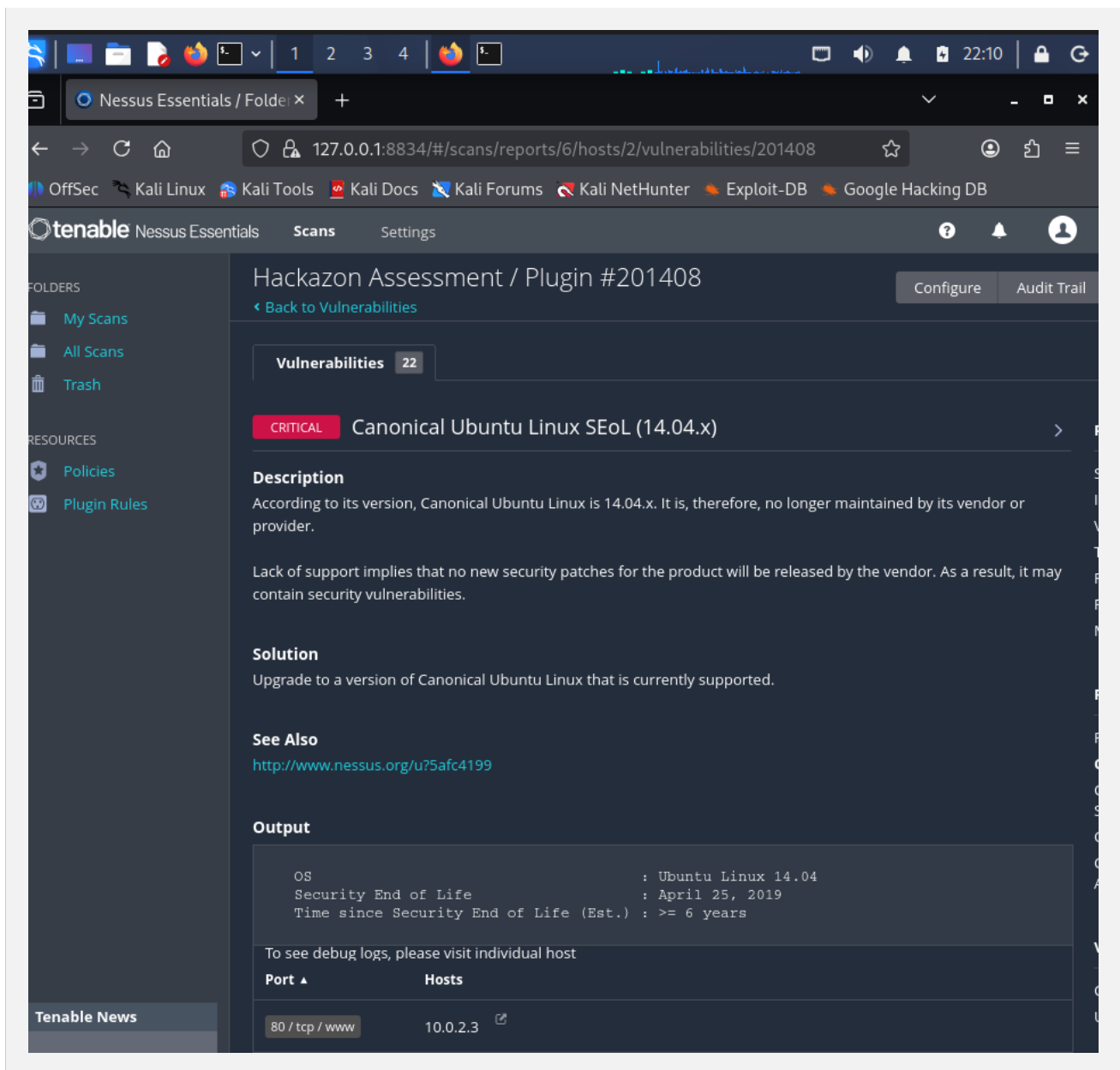


Figure: Ubuntu 14.04 LTS: End of Life Operating System finding as reported by scanner

2. DEBUG HTTP Method Enabled

Field	Details
Severity	High
CVSS Score	N/A
Discovered By	Nikto 2.6.0
Location	http://10.0.2.3/

Description:

Nikto found that the web server accepts the HTTP DEBUG method and returns a valid response. The DEBUG method is an HTTP extension that, when left enabled, can leak internal server information and application details to an attacker.

Potential Impact:

Having the DEBUG method enabled can let an attacker pull sensitive information about the server environment, installed software, and how the application works internally. That information can then be used to plan more focused attacks.

Recommended Remediation:

The DEBUG HTTP method should be disabled in the Apache configuration. This can be done by adding a LimitExcept directive that limits accepted methods to GET, POST, and HEAD. The server should be restarted afterward and tested to confirm the method is no longer available.

```
+ DEBUG /: DEBUG HTTP verb may show server debugging information. See: https://docs.microsoft.com/en-us/visualstudio/debugger/how-to-enable-debugging-for-aspnet-applications?view=vs-2017:
```

Figure: DEBUG HTTP Method Enabled finding as reported by scanner

3. Redis Configuration Files Publicly Accessible

Field	Details
Severity	High
CVSS Score	N/A
Discovered By	Nikto 2.6.0
Location	http://10.0.2.3/redis_config.json, /tests/redis_config.json, /config/redis.json

Description:

Nikto found three Redis configuration files that can be accessed without any authentication using a direct HTTP GET request. These files could contain Redis connection details, login credentials, host addresses, and port numbers used by the application.

Potential Impact:

Exposed configuration files can give an attacker sensitive credentials and information about the internal network. If the Redis instance is reachable and credentials are in these files, an attacker could get direct access to the Redis data store and read, change, or delete cached application data and session tokens.

Recommended Remediation:

Configuration files with sensitive credentials should never be stored inside the web root where the public can reach them. These files should be moved outside the web accessible directory. The web server should also be set up to block direct access to configuration and JSON files using .htaccess rules or Apache Directory directives.

```
+ GET /redis_config.json: Redis config file found. It may contain sensitive information.  
+ GET /credis/tests/redis_config.json: Redis config file found. It may contain sensitive information.  
+ GET /config/redis.json: Redis config file found. It may contain sensitive information.
```

Figure: Redis Configuration Files Publicly Accessible finding as reported by scanner

4. jQuery < 3.5.0: Multiple Cross-Site Scripting (XSS) Vulnerabilities

Field	Details
Severity	Medium
CVSS Score	6.1 (CVSS v3)
Discovered By	Tenable Nessus Essentials
Location	http://10.0.2.3/ (client-side JavaScript)

Description:

Nessus found that the application uses a version of jQuery older than 3.5.0, which has several known XSS vulnerabilities. These issues are in jQuery's HTML parsing and DOM manipulation functions and can be triggered when the application passes untrusted input to methods like .html(), .append(), or .load().

Potential Impact:

XSS vulnerabilities let attackers inject malicious code into pages that other users see. This can be used to steal session cookies, capture login credentials, redirect users to malicious sites, or take actions on behalf of logged in users without them knowing. Since Hackazon handles user accounts and payment flows, XSS is a serious concern.

Recommended Remediation:

jQuery should be updated to version 3.5.0 or later to fix the known XSS issues. The application should also add a Content Security Policy header to help reduce the impact of any XSS vulnerabilities that might exist elsewhere in the app.

The screenshot shows a web application security scanner interface. The browser address bar displays the URL `127.0.0.1:8834/#/scans/reports/6/hosts/2/vulnerabilities/136929`. The page title is "Hackazon Assessment / Plugin #136929". The vulnerability is categorized as "MEDIUM" and titled "jQuery 1.2 < 3.5.0 Multiple XSS".

Description
According to the self-reported version in the script, the version of JQuery hosted on the remote web server is greater than or equal to 1.2 and prior to 3.5.0. It is, therefore, affected by multiple cross site scripting vulnerabilities.

Note, the vulnerabilities referenced in this plugin have no security impact on PAN-OS, and/or the scenarios required for successful exploitation do not exist on devices running a PAN-OS release.

Solution
Upgrade to JQuery version 3.5.0 or later.

See Also
<https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/>
<https://security.paloaltonetworks.com/PAN-SA-2020-0007>

Output

```
URL           : http://10.0.2.3/js/jquery-1.10.2.js
Installed version : 1.10.2
Fixed version  : 3.5.0
```

To see debug logs, please visit individual host

Port ▲	Hosts
80 / tcp / www	10.0.2.3

Figure: jQuery < 3.5.0: Multiple Cross-Site Scripting (XSS) Vulnerabilities finding as reported by scanner

5. Missing Content-Security-Policy Header

Field	Details
Severity	Medium
CVSS Score	N/A
Discovered By	Nikto 2.6.0
Location	http://10.0.2.3/ (HTTP response headers)

Description:

Nikto found that the application does not include a Content-Security-Policy (CSP) header in its HTTP responses. CSP is a browser security feature that tells the browser which sources of content (scripts, styles, images, etc.) are allowed to load on a page, which helps reduce the risk of XSS and data injection attacks.

Potential Impact:

Without a CSP header, browsers will run any scripts on the page with no restrictions, including injected malicious ones. This makes the application more vulnerable to XSS attacks. The missing CSP is very concerning given the jQuery XSS vulnerabilities already found in this assessment.

Recommended Remediation:

A Content-Security-Policy header should be added to all HTTP responses. At minimum, the policy should limit script sources to the application's own origin (script-src 'self') and block inline scripts where possible. It is a good idea to start in report-only mode and tighten the policy gradually to avoid breaking anything.

```
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP:
```

Figure: Missing Content-Security-Policy Header finding as reported by scanner

6. PHPSESSID Session Cookie Missing HttpOnly Flag

Field	Details
Severity	Medium
CVSS Score	N/A
Discovered By	Nmap / Nikto 2.6.0
Location	http://10.0.2.3/ (Set-Cookie response header)

Description:

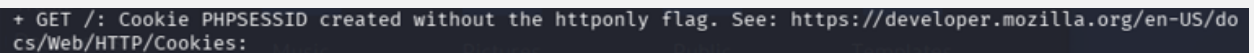
Both Nmap and Nikto found that the PHPSESSID session cookie is set without the HttpOnly flag. The HttpOnly flag tells the browser to block client side JavaScript from reading the cookie. Without it, any JavaScript running on the page can access the session cookie.

Potential Impact:

Without the HttpOnly flag, a session cookie can be stolen by an attacker who pulls off a successful XSS attack. Once they have the cookie, they can impersonate the victim without needing their password, essentially taking over their session. This is directly exploitable alongside the XSS vulnerabilities found elsewhere in this assessment.

Recommended Remediation:

The HttpOnly flag should be enabled on the PHPSESSID cookie through the PHP session settings. This can be done in php.ini by setting `session.cookie_httponly = 1`, or in code using `session_set_cookie_params()` before starting the session. The Secure flag should also be turned on if the application runs over HTTPS.



```
+ GET /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies:
```

Figure: PHPSESSID Session Cookie Missing HttpOnly Flag finding as reported by scanner

6. Risk Summary

The table below summarizes all six vulnerabilities covered in this report, along with their severity and suggested fix priority.

#	Vulnerability	Severity	CVSS	Remediation Priority
1	Ubuntu 14.04 End of Life	Critical	10.0	Immediate
2	DEBUG HTTP Method Enabled	High	N/A	High
3	Redis Config Files Exposed	High	N/A	High
4	jQuery < 3.5.0 Multiple XSS	Medium	6.1	Medium
5	Missing Content-Security-Policy	Medium	N/A	Medium
6	PHPSESSID Missing HttpOnly Flag	Medium	N/A	Medium

Table 5: Risk summary and remediation priorities

7. Recommendations

Based on the findings of this assessment, here are the recommended next steps in order of priority:

1. Upgrade the operating system. Ubuntu 14.04 LTS is well past its end-of-life date. Moving to a supported OS is the most important fix and should be done right away.
2. Disable unnecessary HTTP methods. The DEBUG method should be turned off at the web server level. Only the methods the application actually needs (GET, POST) should be allowed.
3. Secure configuration file storage. Any configuration files with credentials or connection strings need to be moved out of the web root or blocked by server level access controls.
4. Update third party libraries. jQuery should be updated to the latest stable version. It is also worth setting up a regular process to check for outdated dependencies before they turn into security issues.
5. Add HTTP security headers. A Content-Security-Policy, Strict-Transport-Security, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy header should be added to all application responses. These are relatively easy to add and make a big difference in reducing browser level attack surface.
6. Fix session cookie settings. The HttpOnly and Secure flags should be enabled on all session cookies to lower the risk of session hijacking through XSS or network interception.

8. Conclusion

This vulnerability assessment of the Hackazon web application found a range of security issues across the host OS, web server configuration, client side libraries, and HTTP response headers. The most critical finding, the end-of-life operating system, is a risk that cannot be fully addressed by application level fixes alone. The web application findings, including exposed configuration files, missing security headers, and an insecure session cookie, show why it is important to think about security at every layer of a web application.

The three tools used in this assessment, Nmap, Tenable Nessus Essentials, and Nikto, each brought something different to the table. Nmap and Nessus found infrastructure level vulnerabilities, while Nikto focused on the web application and caught issues that a host scanner would have missed. Together, they gave a good overall view of the attack surface.

Fixing the vulnerabilities in this report, starting with the critical and high severity ones, would lower the overall risk. In a real world environment, the issues found here would represent a serious risk to user data, the application, and the organization as a whole.

Supporting Screenshots

The screenshots below were taken during the assessment to document the tools and findings described in this report. All screenshots include system timestamps.

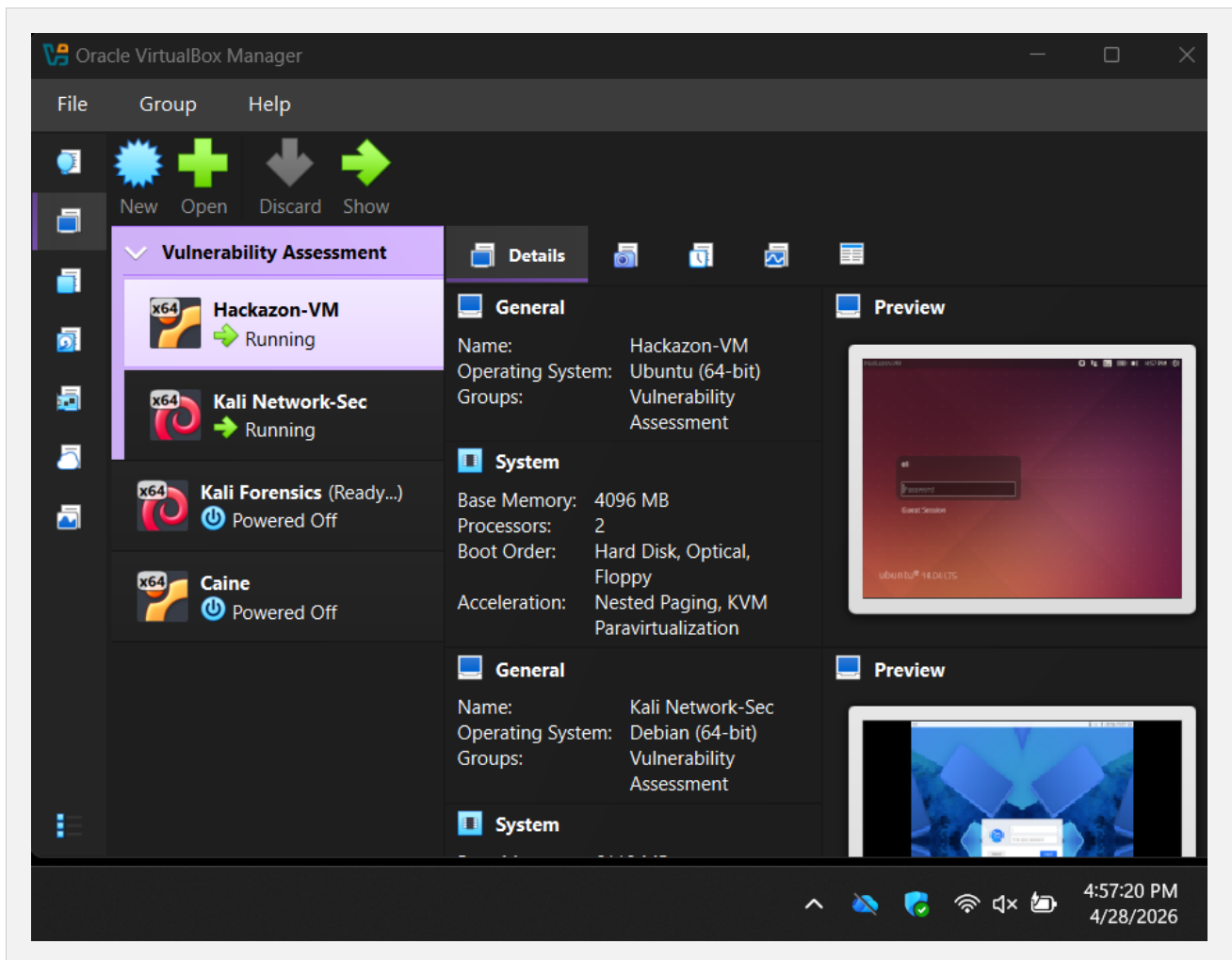


Figure A1: VirtualBox lab environment with both VMs running

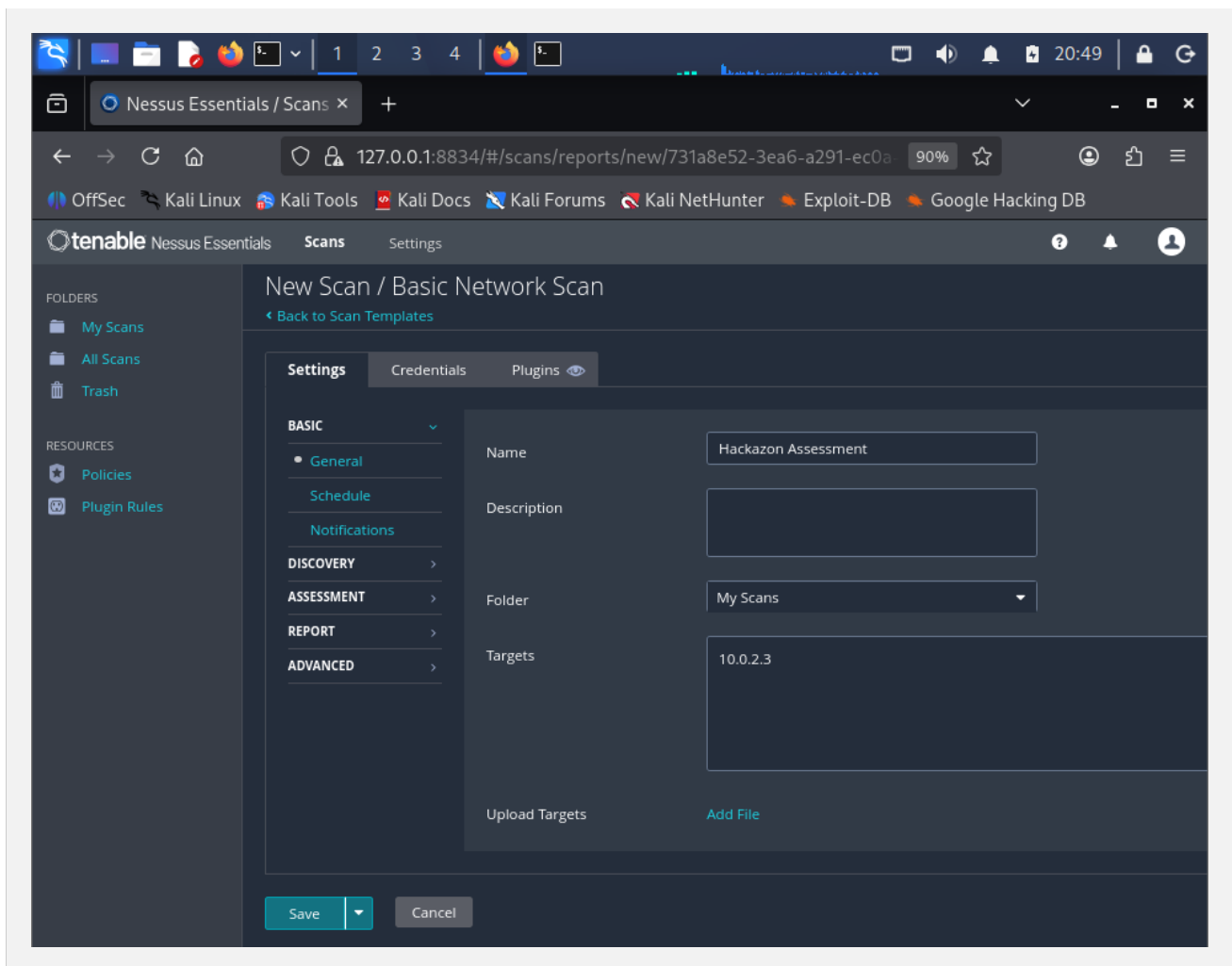


Figure A2: Nessus scan configuration

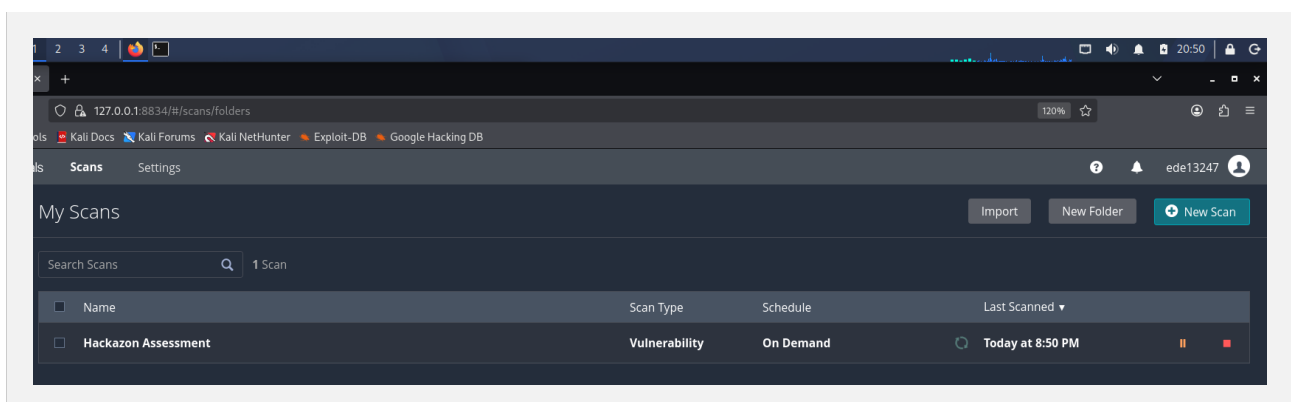


Figure A3: Nessus scan in progress

```
26/04/26 9:01:55 (kali@kali)-[~]  
└─$ nikto -h http://10.0.2.3 -o nikto_results.txt  
- Nikto v2.6.0  
  
+ Your Nikto installation is out of date.  
+ Target IP: 10.0.2.3  
+ Target Hostname: 10.0.2.3  
+ Target Port: 80  
+ Platform: Unknown  
+ Start Time: 2026-04-26 21:02:17 (GMT-4)  
  
+ Server: Apache/2.4.7 (Ubuntu)  
+ [95] /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ [999986] /: Retrieved x-powered-by header: PHP/5.5.9-1ubuntu4.29.  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [600625] PHP/5.5.9-1ubuntu4.29 appears to be outdated (current is at least 8.5.1).  
+ [600050] Apache/2.4.7 appears to be outdated (current is at least 2.4.66).  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
```

Figure A4: Nikto scan initiated from Kali terminal

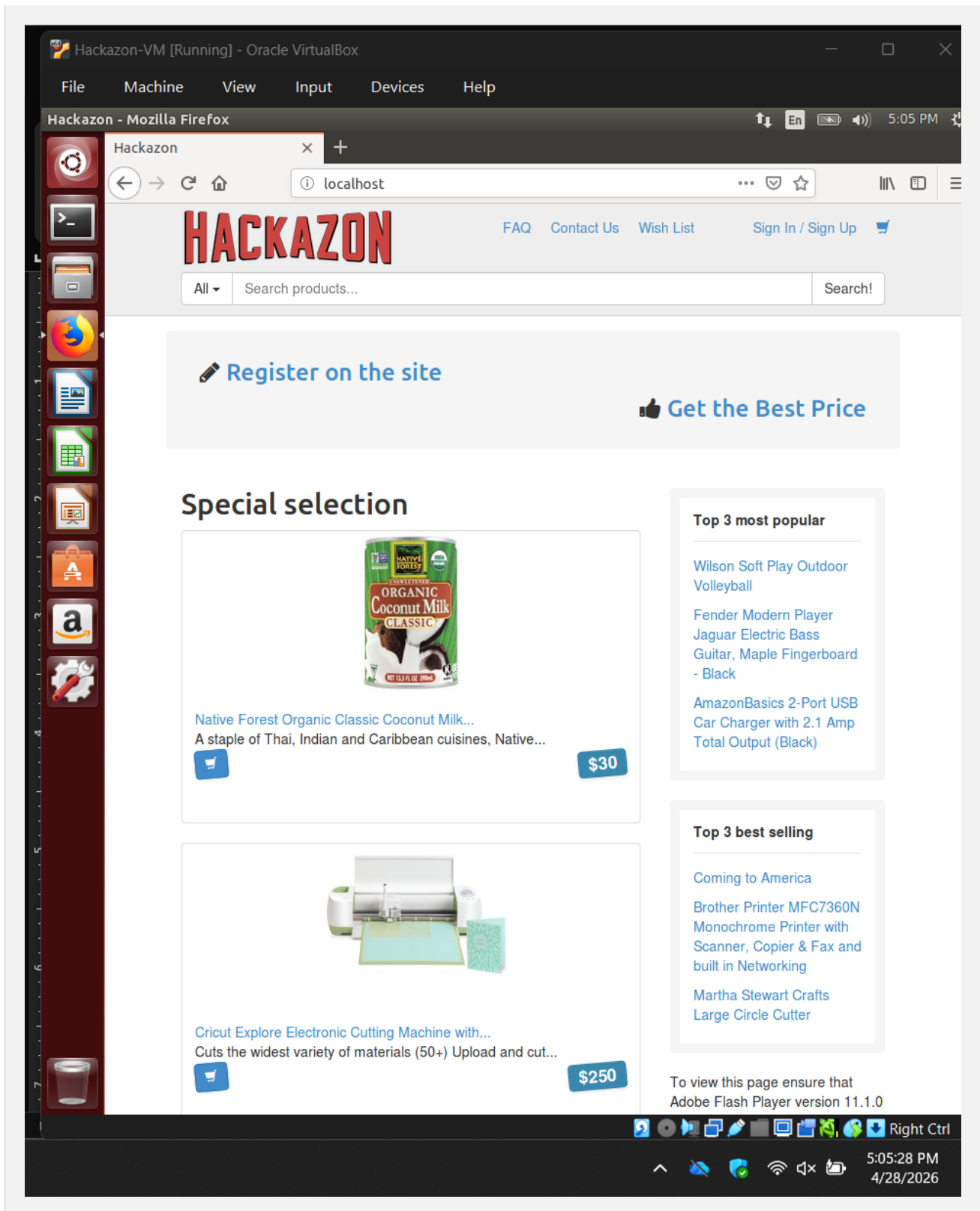


Figure A5: Hackazon application running on target host